



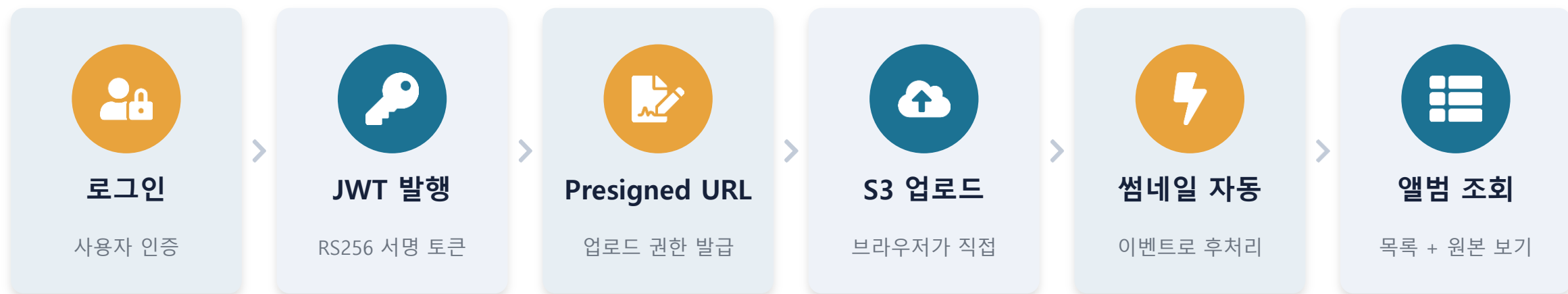
간편앨범으로 배우는

JWT + Presigned URL

AWS 서버리스 파일 업로드 아키텍처 · 핵심 개념

NEXIO · 입문~중급 개발자 대상

한 장으로 보는 전체 흐름



이미지 바이너리는 서버(Lambda)를 거치지 않고 브라우저 ↔ S3 로 직접 오간다 — 그게 이 구조의 핵심.

JWT란 무엇인가

서명된 정보 꾸러미. 점(.)으로 나뉜 세 부분이 한 줄의 문자열을 이룬다.



Header

알고리즘·키 식별

```
alg: RS256  
kid: easyalbum-jwt-key-v2
```



Payload

클레임(주장)

```
sub, iss, aud, role,  
exp ...
```



Signature

위변조 방지 서명

```
개인키로 서명  
공개키로 검증
```

CLAIMS

토큰이 담는 4가지 주장



iss

누가 발행했나

<https://auth-lab.nexioengine.com>



aud

누구를 위한 토큰인가

[myalbum1](#)



sub

누구인가

[james](#)



role

어떤 역할인가

[member](#)

Authorizer는 이 중 iss·aud·만료(exp)·서명을 검증한다.

왜 비대칭 키인가



개인키 (Private)

- 토큰에 '서명'한다
- 오직 발행자만 보유 (EC2 /login)
- 절대 외부 노출 금지



공개키 (Public)

- 서명을 '검증'한다
- 누구나 가져도 안전 (JWKS로 공개)
- 검증자(API Gateway)가 사용

검증자에게 비밀을 나눠줄 필요가 없다 — 그래서 분산 검증에 안전하다.

공개키는 어디서 오나

발행자(auth-lab)가 공개키를 정적 파일로 게시하고, 검증자가 그것을 읽어 검증한다.



auth-lab.nexioengine.com

Cloudflare R2 정적 호스팅

`/.well-known/openid-configuration`

→ issuer · jwks_uri 안내

`/.well-known/jwks.json`

→ 공개키(kid, RS256)



API Gateway

- issuer / audience 설정만으로
- 위 JWKS를 자동으로 읽어
- 서명·iss·aud·exp를 검증

왜 Authorizer가 필요한가

모든 보호 API 앞단에서 토큰을 검증하는 '문지기'. 각 Lambda가 검증 코드를 중복할 필요가 없다.



서명

공개키로 위변조 확인



iss

발행자가 맞는가



aud

이 앱을 위한 토큰인가



exp

만료되지 않았는가

넷 중 하나라도 실패하면 → 401/403, 뒷단 Lambda는 호출조차 되지 않는다.

왜 직접 업로드인가



서버 경유 업로드

- 이미지가 Lambda/API를 통과
- 용량 한도·지연·비용 증가
- 큰 파일에 취약



Presigned URL 직접 업로드

- 서버는 '서명된 임시 URL'만 발급
- 브라우저가 S3로 직접 PUT
- 유효시간 300초, 키/경로 서버 제어

저장 경로 규칙

gallery/original/james/20260615_1718456789012.jpg

gallery

서비스

original

원본 / thumb

james

사용자(sub)

20260615

업로드 일자

1718...012

밀리초 타임스탬프

jpg

확장자

썸네일은 *original* → *thumb* 으로 경로만 바뀐다. 사용자(sub)별로 폴더가 나뉘어 데이터가 격리된다.

S3 이벤트로 썸네일 자동 생성



원본 업로드

gallery/original/ 에 저장



S3 이벤트 발생

ObjectCreated 트리거



Lambda 썸네일

리사이즈 → gallery/thumb/



무한루프 주의 트리거는 original/ prefix 에만 — 썸네일을 thumb/ 에 쓰는 동작이 다시 트리거되지 않도록.

비공개 버킷을 안전하게 보여주기



ListObjectsV2

본인 thumb/{sub}/ prefix 의 키 목록 조회



presigned GET

각 키에 임시 조회 URL 발급(유효시간 적용)



브라우저 표시

버킷은 비공개인데도 안전하게 렌더

버킷을 공개하지 않고도 조회가 된다 — 노출 위험 없이 '필요한 사람에게 잠깐만' 보여주는 방식.

구성요소 한눈에



EC2 / auth-server

로그인 · JWT(개인키) 서명 · 웹 클라이언트



auth-lab (R2)

JWKS · OIDC discovery (공개키 게시)



API Gateway + Authorizer

issuer/audience로 토큰 검증



Lambda presign-creator

presigned PUT URL 발급



Lambda thumbnailer

S3 이벤트 → 썸네일(sharp)



Lambda album-list

ListObjectsV2 + presigned GET

이제 설명할 수 있어야 할 것



JWT란 무엇이며 iss/aud/sub/role의 의미



RS256: 개인키 서명 · 공개키 검증의 원리



JWT Authorizer가 왜 필요한가



Presigned URL을 왜 사용하는가



S3 Event Trigger란 무엇인가



서버리스 업로드 아키텍처 전체 구성



이제 직접 만들어 봅시다

간편앨범 · Simple Album

로그인 → JWT → presigned URL → S3 → 썸네일 → 조회